

Endpoint: `https://api.tripwheel.app/api/v1/bookings/traveller/verify-code`

```
equest-code","message":"100 many requests for this booking. Please wait and try again."}
--- Request #3 ---
HTTP Status: 429
{"statusCode":429,"timestamp":"2026-08-01T13:32:32.913Z","path":"/api/v1/bookings/traveller/verify-code","message":"ThrottlerException: Too Many Requests"}
```

RECORD YOUR RESULTS:

- Did every request return 201 Created, or did later ones get blocked?
- Check your inbox: did you receive that many separate codes?

```
> ./02_test_otp_verify.sh 5
zsh: permission denied: ./02_test_otp_verify.sh
> chmod +x 02_test_otp_verify.sh
> ./02_test_otp_verify.sh 5
=== Submitting 5 WRONG codes in a row for: 231jabedhasan@gmail.com ===
```

--- Attempt #1, trying code: 016112 ---

```
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:45:12.809Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
```

--- Attempt #2, trying code: 018838 ---

```
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:45:13.983Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
```

--- Attempt #3, trying code: 006543 ---

```
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:45:15.204Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
```

--- Attempt #4, trying code: 009268 ---

```
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:45:16.342Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
```

--- Attempt #5, trying code: 011994 ---

```
HTTP Status: 429
{"statusCode":429,"timestamp":"2026-08-01T13:45:17.474Z","path":"/api/v1/bookings/traveller/verify-code","message":"ThrottlerException: Too Many Requests"}
```

RECORD YOUR RESULTS:

- Did it ever say 'too many requests' / 429, or did it just keep saying 'invalid code' forever?
- If it NEVER blocks wrong guesses, that is a real finding: the code can be brute forced.

```

> ./02_test_otp_verify.sh 15
=== Submitting 15 WRONG codes in a row for: 231jabadhasan@gmail.com ===

--- Attempt #1, trying code: 011493 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:48:56.485Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #2, trying code: 015127 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:48:57.610Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #3, trying code: 001923 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:48:58.734Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #4, trying code: 004649 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:48:59.868Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #5, trying code: 007375 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:49:00.997Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #6, trying code: 027848 ---
HTTP Status: 429
{"statusCode":429,"timestamp":"2026-08-01T13:49:02.132Z","path":"/api/v1/bookings/traveller/verify-code","message":"ThrottlerException: Too Many Requests"}
--- Attempt #7, trying code: 030573 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:49:03.271Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #8, trying code: 000531 ---
HTTP Status: 429
{"statusCode":429,"timestamp":"2026-08-01T13:49:04.396Z","path":"/api/v1/bookings/traveller/verify-code","message":"ThrottlerException: Too Many Requests"}
--- Attempt #9, trying code: 003257 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:49:05.529Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}
--- Attempt #10, trying code: 022821 ---
HTTP Status: 401
{"statusCode":401,"timestamp":"2026-08-01T13:49:06.653Z","path":"/api/v1/bookings/traveller/verify-code","message":"Invalid or expired code"}

```

Comment : The OTP has rate limiting, but it resets quickly. This means someone can keep trying wrong codes slowly instead of being fully blocked after several failed attempts.

Endpoint: `https://islandtours.tripwheel.appcuracao/thank-you/{{booking_id}}`

The screenshot shows a web security tool interface. The top bar indicates the current view is "View booking as Traveller B (with session)". The request is a GET to `curacao/thank-you/{{booking_id}}`. The response status is 200 OK. The response body is HTML, showing a booking confirmation page. The page content includes a booking reference, tour date, duration, and pricing. A red box highlights a security warning in the tool's interface, stating: "This is a security test — Traveller B is viewing Traveller A's booking. The best visualization is a dashboard card showing the booking details that were waiting for approval..."

Key	Value	Description
accept	*/*	
Cookie	NEXT_LOCALE=en; NEXT_CURRENCY=USD;...	
referer	https://islandtours.tripwheel.app/en/traveller	

```
<!DOCTYPE html>
<html lang="en" class="h-full antialiased bricolage_grotesque_defd82b2-module__bj-ayq__variable source_sans_3_ff427fcc-module__PTodPG__variable jetbrains_mono_7d65b77b-module__VxV-Ta__variable font-sans">
  <head>
    <meta charSet="utf-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1" />
    <link rel="preload" as="image" imageSrcSet="/_next/image?url=https%3A%2F%2Fres.cloudinary.com%2Fdfsms7jb4%2Fimage%2Fupload%2Fv1%2Fislandtours%2Fusers%2Fi1Z8MYF68Ib1lIC3ctwVqy1A9PjZ3mp%2Fau31t7lk9gihdmneaxxc%3F_ak3DBAMAPqcg%26amp;w=96&q=75 1x, /_next/image?url=https%3A%2F%2Fres.cloudinary.com%2Fdfsms7jb4%2Fimage%2Fupload%2Fv1%2Fislandtours%2Fusers%2Fi1Z8MYF68Ib1lIC3ctwVqy1A9PjZ3mp%2Fau31t7lk9gihdmneaxxc%3F_ak3DBAMAPqcg%26amp;w=256&q=75 2x" />
    <link rel="stylesheet" href="/_next/static/chunks/14h1logrfaf_6.css" data-precedence="next" />
    <link rel="stylesheet" href="/_next/static/chunks/0m6-7g77c03xk.css" data-precedence="next" />
    <link rel="preload" as="script" fetchPriority="low" href="/_next/static/chunks/0qz0lqgpbka7.js" />
    <script src="/_next/static/chunks/082jrtaw3rbgp.js" async=""></script>
```

- Booking ref: IT-2026-MADN2
- Tour date: Wed, 5 Aug 2026, 10:00 AM – 1:00 PM
- Duration: 3h
- Free cancel: Before Tuesday 4 August
- Operator: Island Roots Tours
- Traveler: 1 adult
- Extras: 2 x Rum flight upgrade
- Paid in full: \$113.00
- Total: \$113.00
- Security context: "Some details are hidden" (Traveller B sees masked info — no traveller name)

This is a security test — Traveller B is viewing Traveller A's booking. The best visualization is a dashboard card showing the booking details that were waiting for approval...

Comment : Anyone with the booking URL can view the booking summary without being the owner or even logged in. We tested this with Traveller B's session and with no session, and both worked without any access check. The page shows the tour details, date, time, operator, extras, amount paid, and booking reference, while personal details like name and email remain hidden. Since the booking reference is also used when contacting support, anyone who gets the URL could potentially use it to impersonate the traveller and request a cancellation or refund.

Endpoint: POST <https://api.tripwheel.app/api/v1/bookings/quote>

Request #45	->	quod:	32d29995-559c-47ab-882d-d8fc38c929f1	totalRetail:	139
Request #46	->	quod:	650a3c63-2e5a-42ef-81d3-806a94cd997f	totalRetail:	139
Request #47	->	quod:	8e2647de-bb85-4d4f-a4af-85d3925262df	totalRetail:	139
Request #48	->	quod:	694e16e2-ad6e-4a8a-b025-f68c7932bbf8	totalRetail:	139
Request #49	->	quod:	f4ac3c6b-152a-4d81-9981-ecf3bb6f8532	totalRetail:	139
Request #50	->	quod:	totalRetail:		
Request #51	->	quod:	totalRetail:		
Request #52	->	quod:	totalRetail:		
Request #53	->	quod:	fee5024e-449a-417a-9d1f-b26bb49966a1	totalRetail:	139
Request #54	->	quod:	totalRetail:		
Request #55	->	quod:	6ca5e8de-e39c-479a-e200-a22cac063c13	totalRetail:	139
Request #56	->	quod:	7bc4863b-0074-42fb-a9bf-ed31497fe7ce	totalRetail:	139
Request #57	->	quod:	totalRetail:		
Request #58	->	quod:	7e82ef5f-19bb-4fa7-9404-3d473a2823d3	totalRetail:	139
Request #59	->	quod:	totalRetail:		
Request #60	->	quod:	428d2f39-4679-4d69-b5dc-144299455642	totalRetail:	139
Request #61	->	quod:	totalRetail:		
Request #62	->	quod:	42b53439-8058-45e1-a6b3c-6baeb31e6d24	totalRetail:	139
Request #63	->	quod:	f0be7731-bc0a-44df-a2a5-940f7f99e527a	totalRetail:	139
Request #64	->	quod:	9c853755-bb6a-4d31-bc21-1971c0ee44d6	totalRetail:	139
Request #65	->	quod:	8821a143-8abb-448a-8c05-57fd38f93b5	totalRetail:	139
Request #66	->	quod:	totalRetail:		
Request #67	->	quod:	577f6018-d25f-45cc-97a9-33724ca3266	totalRetail:	139
Request #68	->	quod:	totalRetail:		
Request #69	->	quod:	totalRetail:		
Request #70	->	quod:	176413fc-af87-46b1-9118-4464bd1a5ec2	totalRetail:	139
Request #71	->	quod:	totalRetail:		
Request #72	->	quod:	totalRetail:		
Request #73	->	quod:	c0d060c2-c7cc-410d-826c-fcea6f220763	totalRetail:	139
Request #74	->	quod:	totalRetail:		
Request #75	->	quod:	totalRetail:		
Request #76	->	quod:	totalRetail:		
Request #77	->	quod:	totalRetail:		
Request #78	->	quod:	7982d560-d1c8-4a0a-83ce-07fd735710469	totalRetail:	139
Request #79	->	quod:	2d3fee42-f507-41f6-bb00-29953a119919	totalRetail:	139
Request #80	->	quod:	totalRetail:		

Comment :The booking quote endpoint starts having problems when around 100 requests are sent at the same time. At this level, about 40% of the requests fail or are dropped without a clear error. The endpoint does not require login, so anyone can access it. Under heavy traffic, this could stop real travellers from getting quotes or completing their bookings.

Name on card

md jaded

Postal code (locale-aware) *

3724

This field is required

After the adding field is required , still showing the error message.



2 of 322 < >





You're booked, Md.

Booking reference: **IT-2026-MADK2**



Curaçao Street Food & Market Tour

Island Roots Tours

Wednesday, 5 August 2026 · 10:00

 Meeting point: Willemstad departure point. [Open in Maps](#)



Please arrive 30 minutes early.



Ends at: Return to Willemstad



Guests: 1 adult



Duration: 3 hours



Language: English, Spanish, Dutch

[View tour details](#)

[Add to calendar](#)

PAYMENT

Paid in full

\$113.00

In the confirmation email , showing language , does this have any meaning ?